

timing attack to guess the password in gradio-app/gradio

✓ Valid

Reported on Feb 12th 2024

BUG

timing attack to guess the password

STEP TO REPRODUCE

There is insufficient password check present in <https://github.com/gradio-app/gradio/blob/17fb116492f951ab66e3a39b5fdb598f5446b6f/gradio/routes.py#L275>

```
if (
    not callable(app.auth)
    and username in app.auth
    and app.auth[username] == password
) or (callable(app.auth) and app.auth.__call__(username, password)):
```

This condition is vulnerable to timing attack to guess the password via timing attack due to `and app.auth[username] == password` here is more details about this type vulnerability <https://ropesec.com/articles/timing-attacks/>

vulnerable code snippet

```
@app.post("/login")
@app.post("/login/")
def login(form_data: OAuth2PasswordRequestForm = Depends()):
    username, password = form_data.username.strip(), form_data.password
    if app.auth is None:
        return RedirectResponse(url="/", status_code=status.HTTP_302_FOUND)
    if (
        not callable(app.auth)
        and username in app.auth
        and app.auth[username] == password
    ) or (callable(app.auth) and app.auth.__call__(username, password)):
        token = secrets.token_urlsafe(16)
        app.tokens[token] = username
        response = JSONResponse(content={"success": True})
        response.set_cookie(
            key=f"access-token-{app.cookie_id}",
            value=token,
            httponly=True,
```

```

        samesite="none",
        secure=True,
    )
    response.set_cookie(
        key=f"access-token-unsafe-{app.cookie_id}",
        value=token,
        httponly=True,
    )
    return response
else:
    raise HTTPException(status_code=400, detail="Incorrect credentials.

#####
# OAuth Routes
#####

# Define OAuth routes if the app expects it (i.e. a LoginButton is defined)
# It allows users to "Sign in with HuggingFace".
if app.blocks is not None and app.blocks.expects_oauth:
    attach_oauth(app)

#####
# Main Routes
#####

```

Impact

timing attack to guess the password

Occurrences

 routes.py L267-L303

 We are processing your report and will contact the **gradio-app/gradio** team within 24 hours. 2 years ago

 We have contacted a member of the **gradio-app/gradio** team and are waiting to hear back 2 years ago



Abubakar Abid gave praise 2 years ago

★ The researcher's credibility has slightly increased as a result of the maintainer's thanks: +1



 **Dan McInerney** modified the Severity from Critical (9.1) to Medium (5.9) 2 years ago



Dan McInerney commented 2 years ago

[Admin](#)

Do you have a PoC to show how to actually exploit this?

✉ We have sent a follow up to the **gradio-app/gradio** team. We will try again in 4 days. 2 years ago

✉ We have sent a second follow up to the **gradio-app/gradio** team. We will try again in 7 days. 2 years ago

★ The researcher has received a minor penalty to their credibility for miscalculating the severity: -1



✓ Abubakar Abid validated this vulnerability 2 years ago

\$ **ranjit-git** has been awarded the disclosure bounty ✓

\$ The fix bounty is now up for grabs

★ The researcher's credibility has increased: +7

🔗 CVE-2024-1729 assigned to this report. 2 years ago



✓ Abubakar Abid marked this as fixed in **4.19.2** with commit **e329f1** 2 years ago

\$ The fix bounty has been dropped ✗

\$ **routes.py#L267-L303** has been validated ✓

⚠ We have sent a warning to the **gradio-app/gradio** team to inform them that this report will be published in 48 hours 2 years ago

📡 This vulnerability has now been published 2 years ago

🔗 CVE-2024-1729 has now been published 2 years ago

[Sign in](#) to join this conversation

CVE
CVE-2024-1729
Published

Vulnerability Type
CWE-367: Time-of-check Time-of-use (TOCTOU) Race Condition

Severity
Medium (5.9)

Attack vector	Network
Attack complexity	High
Privileges required	None

User interaction	None
Scope	Unchanged
Confidentiality	High
Integrity	None
Availability	None

[Open in visual CVSS calculator](#) 

Registry

Pypi

Affected Version

4.18.0

Visibility

Public

Status

Fixed

Disclosure Bounty

\$125

Fix Bounty

\$31.25

Found by



ranjit-git

@ranjit-git

LIGHTWEIGHT



Supported by [Palo Alto Networks](#) and Prisma AIRS, leading the way to greater AI security.

